Privacy and security note · Udyam OneFlow

Team Lead by Lord · VIT Chennai · Airtel SYNC 2026, Track A, Project Udyam Digital · Prototype built on synthetic data supplied by the organisers

Consent and notice	A plain-language screen appears before any document is read, in English, Hindi or Tamil: what we read, why, and for how long. The owner must tap Agree. Withdrawing consent stops processing at once and deletes the uploaded images; the owner can withdraw as easily as they agreed.
Purpose limitation	Documents are used only to verify this order. They are not used for marketing, and not used to train any model.
Data minimisation	Only the fields each check needs are collected. Extracted fields are stored, not the full OCR text. Aadhaar and PAN numbers are not requested in the chat.
Identifier masking	Identifiers are masked in the app, in logs and in anything the LLM sees, for example GSTIN 27••••••••••1ZL and Udyam UDYAM-KL-00-•••7801. Logs never hold raw identifiers.
OCR and documents	OCR (RapidOCR) runs locally on the server. Documents are never sent to the LLM. The owner sees every extracted field and can edit a misread one before checks run. Uploads are not publicly accessible, with file type and size limits.
Retention and deletion	Raw images: deleted on withdrawal; otherwise flagged for deletion on completion or within 7 days (the scheduled purge job is a rollout item, not yet built). Chat transcripts: 30 days. Extracted fields of a completed order: kept for the contract term (to be confirmed with legal).
Owner rights	The owner can view, correct, delete or withdraw their data from the app. Requests and complaints go to the support contact shown in the app; production adds a named Data Protection Officer.
LLM data protection	The LLM (Gemini, with OpenRouter fallback) is used for language only: extracting the business profile and explaining the plan. It sees masked context, never documents. Prices, fees and eligibility come from rules and the catalogue, and an output validator rejects any number the model invents. The product also works with the AI switched off.
Security controls	Short-lived sessions; secrets held in environment variables, not in code; an audit log of actions; upload type and size limits; non-public file storage.
Simulated and planned	Simulated and labelled in the app: DigiLocker document fetch, WhatsApp Business API, Aadhaar OTP e-sign, e-NACH mandate. Planned: OSS/BSS provisioning. Registry lookups use the organisers' mock GSTIN (3,534) and Udyam (2,723) records. All data is synthetic.
Production readiness	Before real customers: live DigiLocker consent flow, production e-sign, KMS encryption of stored data, the scheduled deletion job, retention periods confirmed with legal, a named Data Protection Officer, a breach-response process, and an independent security review.

This prototype is designed in line with the principles of the Digital Personal Data Protection Act, 2023 (consent, purpose limitation, data minimisation). It is not a legal compliance certification, and this note describes the prototype, not a production service. Code: github.com/vikramhls/airtel